

commercial-roadmap

Commercial Roadmap

Preston-Check is **fully open source under Apache 2.0**. Every check, every framework filter, every report format runs free for every user — no license required, no signup, no email gate, no tier-locked features in the scanner itself. The 294 checks (284 main catalog + 10 deep smart-contract module) across 33 frameworks are yours to run on any codebase, any time, with output identical to what paying customers get from the scanner alone. AI augmentation (`--ai-augment` , `--ai-fix`) is also fully open source — bring your own API key.

The commercial product is **not the scanner**. It's the audit-package SaaS at `app.preston-check.com` (customer portal) and `admin.preston-check.com` (operator portal) that consumes scanner output and produces auditor-ready deliverables. This document describes that SaaS at a high level; the detailed surface design and KPI catalog live in `docs/portals-and-kpis.md`.

Why open core

Modern dev-tools companies (Snyk, Semgrep, Trivy, Vercel, Supabase, GitLab) all use this model: the scanner / engine / framework is genuinely free, and the commercial product is a SaaS layer that wraps it. The scanner being free is what makes adoption viral. The SaaS being closed is what funds the engineering team that maintains both.

Generously free open-source isn't a sustainability problem — it's the acquisition channel that fills the SaaS funnel. The Snyk playbook (10,000 free users → 200 paying SaaS customers → \$50M ARR) only works because the scanner has zero adoption friction.

What the audit-package SaaS does

The scanner produces `report.md` locally. The SaaS at `preston-check.com/dashboard` takes that report (paste, upload, or POST via API from the GitHub Action) and produces deliverables that auditors and CISOs actually buy:

Branded PDF reports. Your company logo, your color scheme, your contact information on the cover. Designed for handing to a SOC 2 / PCI / ISO auditor as evidence. Free output is markdown / unbranded PDF; paid output is a polished deliverable on your letterhead.

Multi-repo aggregation. Roll up scanner output across every repository in your organization into a single dashboard. Trends over time. Heat map of which checks are failing where. Compare your scores to anonymized benchmarks across other fintechs in your size class.

Compliance-evidence bundling. Group findings by framework control (PCI-DSS 6.5.1, SOC 2 CC6.1, etc.) and produce evidence packets — the format auditors expect. The framework metadata in the open scanner is what makes this possible; the SaaS is what packages it.

Customer portal. License management, team-member access, billing, history of past scans, exportable evidence archives. Pay-by-credit-card self-serve up to Pro tier; sales-led for Enterprise.

SSO and audit logs. SAML / OIDC integration for Enterprise customers whose security teams require it. Per-user access controls. Tamper-evident audit logs of who scanned what and when.

Custom check authoring service. Enterprise customers can request custom checks tailored to their internal compliance program. Maintainer team builds, tests, and includes them privately for that customer.

SLA and dedicated support. Email and Slack support for Pro; dedicated success contact and quarterly architecture reviews for Enterprise.

Pricing

Free — \$0, no license, no email. Full scanner. Markdown reports. PDF reports via local pandoc. Manually-uploaded scan results to the public scorecard if opted in. Forever, no expiry.

Pro — \$999/repo/yr or \$4,999/yr unlimited repos. Adds: branded PDF generation in the SaaS, multi-repo dashboard, compliance-evidence bundling, customer portal, priority email support. Most fintechs preparing for SOC 2 or PCI audits land here.

Enterprise — \$29,999+/yr starting. Adds: SSO, white-label reports (your logo replaces Preston-Check), custom check authoring service, signed audit packages, dedicated customer-success contact, on-premise deployment options for the dashboard, SLA-backed support.

OSS exemption (Pro free for OSS repos)

Repositories with a recognized OSS LICENSE file (MIT, Apache, BSD, GPL, MPL, ISC, Unlicense) automatically receive free Pro-tier dashboard access. Public security work makes the community stronger; a fintech that maintains an open-source library shouldn't pay to scan their own community contribution.

Roadmap by quarter

Q3 2026 — Customer Portal v1. Repos list, latest scan view, Stripe billing integration, manual scan upload, branded PDF generation. Magic-link auth. Launch goal: first paying Pro customer.

Q4 2026 — Admin Portal v1. Customer list, license issuance UI (replacing the current `tools/issue-license.sh` shell flow), revenue dashboard mirroring Stripe, support ticket inbox. Launch goal: operator runs the entire business from the portal without shell access. SSO (SAML + OIDC) and white-label complete the Enterprise feature surface for first-contract conversations.

Q1 2027 — Compliance v2 + multi-repo aggregation + State of Fintech Security report.

Framework-control rollups, evidence-bundle generation, multi-repo trends, peer percentiles (once telemetry has volume). Annual report aggregates opt-in anonymized telemetry into an industry benchmark — free download with email gate. Goal: first Enterprise contract.

Q2 2027 — Threat-intel triage UI + AI feedback loop + compliance-platform integrations. Move `checks/community/proposed/` review into the Admin Portal with a regex-tester. Capture user "false-positive" / "fix accepted" signals into the AI training set so model quality improves quarter over quarter. Drata, Vanta, Secureframe, Tugboat Logic push Preston-Check evidence directly into compliance platforms as evidence-of-control.

Q3 2027 — SSO + advanced enterprise. Audit logs, on-premise deploy option for high-regulation customers. Goal: 5+ Enterprise customers running mission-critical compliance through the portal.

Project identity

The maintainers run Preston-Check pseudonymously. Customer-facing communications, releases, conference talks, and the State of Fintech Security report attribute to "Preston" (or the collective "Preston-Check Maintainers"). The legal operating entity that signs contracts and receives Stripe payouts is a separate, publicly-registered LLC; no public-facing artifact links the pseudonym to the underlying individual. The full strategy is documented at [docs/strategy/anonymity-and-](#)

`mystique.md`. Customers, auditors, and partners interact with the LLC through normal commercial channels — KYC, contract signing, Stripe billing — without the pseudonymity ever being load-bearing on their side.

What's never paid

The scanner itself. Every check. Framework filtering. Severity filtering. Findings format. The lib/modules. Markdown and PDF output. The GitHub Action. The Docker image. The Homebrew formula. The community contribution model. Apache 2.0 forever.

Forking the scanner is welcome and explicitly fine. Anyone can run a forked scanner privately or commercially. The Preston-Check trademark and the audit-package SaaS are what's protected — your fork can't call itself "Preston-Check Pro" and it can't access the dashboard or issue licenses.

How to support sustainability

The audit-package SaaS funds the maintenance team that keeps the scanner current as new frameworks publish, new attack patterns emerge, and new languages mature. The most direct way to support continued open-source development is to subscribe at Pro or Enterprise tier and get the SaaS deliverables in return. The second-most-direct way is to contribute checks via the trust-tier system in `CONTRIBUTING.md` — verified-tier authors are eligible for the bounty program.

Bug reports, feature requests, framework suggestions, and PRs are always welcome regardless of tier.